



GOVERNANCE PROGRAM

Cybersecurity & Data Protection Governance Program

Defines the lightweight cybersecurity governance program for Masar Zero — a small founder-led startup that delegates security to subprocessors.

This policy establishes the Masar Zero cybersecurity and data protection governance program. It is intentionally lightweight: founders wear all hats, most security work is done by subprocessors, and the program is reviewed annually. The policy is honest about scope limitations and credits subprocessors for the controls they provide.

PREPARED BY	Masar Zero W.L.L.
DOCUMENT ID	MZ-POL-001
VERSION	v1.0
EFFECTIVE	12 July 2026
CLASSIFICATION	Internal Use — Authorized Recipients Only

Document Control

Document ID	MZ-POL-001	Version	v1.0
Effective Date	12 July 2026	Review Cycle	Annual (next review: July 2027)
Document Owner	Dr. A. Latif Alkhaja	Classification	Internal Use
Publisher	Masar Zero W.L.L.	Contact	hari@masarzero.com

Revision History

Version	Date	Author	Summary of Change
v1.0	12 July 2026	Masar Zero	Initial release of Cybersecurity & Data Protection Governance Program.

Approval

This document is prepared by Hari Krishna and approved by Dr. A. Latif Alkhaja, Chairman of Masar Zero W.L.L. It is effective as of the date shown above and is reviewed annually or upon significant change per MZ-POL-001 §7. Distribution is restricted to authorized recipients; redistribution requires written approval from Masar Zero leadership.

Role	Name	Signature	Date
Prepared by	Hari Krishna		
Approved by	Dr. A. Latif Alkhaja (Chairman)		

1. Purpose & Honest Scope Statement

This policy establishes the Masar Zero W.L.L. ("Masar Zero") cybersecurity and data protection governance program. Masar Zero is a small founder-led startup that operates a Stage III Vapor Recovery Unit (VRU) deployed at customer service stations. The program is designed to be proportionate to: (a) the limited data footprint of the deployment (only hourly aggregate gasoline-recovered data is stored), (b) the air-gapped architecture (station-side equipment connects to an external network, not the customer's corporate network), and (c) the small team size (founders only, no dedicated security staff).

Honest scope statement. Masar Zero is a small startup, not a software company. We do not operate our own hardened Linux servers, host-based intrusion detection, mobile device management, formal secure-software-development lifecycle, or annual third-party penetration testing. We rely on best-in-class subprocessors (WorkOS, Vercel, Supabase, WeCon cloud, Google Workspace, GitHub, 1Password) to provide security controls as platform features, and we configure those platforms per vendor guidance. This policy describes what Masar Zero actually does, not what an enterprise-grade security program would look like.

2. Scope

This policy applies to: (a) Masar Zero founders and any future employees or contractors with access to Masar Zero information systems; (b) all Masar Zero cloud resources hosted on Vercel, Supabase, WorkOS, WeCon cloud, Google Workspace, GitHub, and 1Password; (c) the WeCon V-Net box and router deployed at customer service stations; (d) all subprocessors engaged by Masar Zero.

The policy does not apply to customer-operated systems. The Masar Zero VRU deployment is air-gapped from the customer corporate network by design; no traffic flows in either direction. This air-gap is documented in the master questionnaire response (BAPCO-QR-001 Section 2) and is treated as a fundamental architectural assumption across all policies in the MZ-POL-001 through MZ-POL-012 suite.

3. Roles & Responsibilities

Masar Zero is a founder-led startup. There is no dedicated CISO, InfoSec Lead, or security team. Founders wear all hats. The cybersecurity program is owned and operated collectively by the founders. Detailed RACI assignments for individual cybersecurity activities are documented in the master questionnaire response (BAPCO-QR-001 Section 5).

3.1 Masar Zero Founders (Accountable & Responsible)

Masar Zero is led by two founders: Dr. A. Latif Alkhaja (Chairman — business leadership, governance, customer relations) and Hari Krishna (technical operations, security configuration, product development). Both founders are collectively accountable for the cybersecurity program. Detailed responsibilities:

- Collective accountability for the cybersecurity program.

- Configuration of all subprocessors (WorkOS, Vercel, Supabase, WeCon cloud, Google Workspace, GitHub, 1Password) per vendor guidance.
- Founder laptop security (built-in disk encryption, OS auto-update, 1Password for credential management).
- Incident response — founders handle all incidents directly; no dedicated IR team.
- Annual policy review and approval.
- Vendor (subprocessor) due diligence at onboarding and annually.

3.2 Subprocessors (Operational)

WorkOS (authentication), Vercel (hosting), Supabase (storage), WeCon cloud (telemetry platform), Google Workspace (email/docs), GitHub (source code), and 1Password (password manager) operate the underlying platforms on which Masar Zero runs. They are responsible for the security of their platforms and provide attestation reports (SOC 2 Type II, ISO 27001) annually. Masar Zero retains responsibility for the configuration and use of those platforms. Each subprocessor is contracted under terms that include breach notification clauses aligned with GDPR Article 33.

4. Governance Framework

The Masar Zero cybersecurity program is structured around the fifteen control domains enumerated in the Bapco cybersecurity and data protection questionnaire. Each domain has a designated policy or procedure (see Section 6 References) that defines the specific controls, implementation evidence, and review cadence. This top-level policy binds those domain-specific policies into a single coherent program.

The program is risk-based and minimal. Masar Zero maintains a lightweight risk register (a Google Sheet) listing the top risks and the subprocessor controls that mitigate them. The risk register is reviewed annually by founders. Risks scoring high are escalated to founders for a continue-or-mitigate decision; there is no formal risk scoring matrix because the small team can discuss risks directly.

5. Policy Suite Structure

The Masar Zero policy suite consists of twelve documents, each addressing one or more control domains. The table below maps policy IDs to control domains and provides a one-line scope statement for each.

Policy ID	Title	Coverage
MZ-POL-001	Cybersecurity & Data Protection Governance Program	Governance
MZ-POL-002	Data Privacy Policy	Data privacy
MZ-POL-003	Access Control & Identity Management Policy	Identity & access
MZ-POL-004	Continuous Monitoring & Log Management Procedure	Monitoring
MZ-POL-005	Vulnerability & Patch Management Policy	Vulnerability mgmt

Policy ID	Title	Coverage
MZ-POL-006	Network Security Policy	Network, crypto, capacity
MZ-POL-007	Incident Response Plan	Incident response
MZ-POL-008	Security Awareness & Training Policy	Awareness
MZ-POL-009	Secure Software Development Practices Policy	Development
MZ-POL-010	Configuration Management & Secure Baseline Standard	Configuration
MZ-POL-011	Endpoint Security & Mobile Device Management Policy	Endpoint, MDM
MZ-POL-012	Business Continuity & Disaster Recovery Plan	BC/DR

Table 1 — Masar Zero policy suite inventory.

6. Subprocessor Due Diligence

Masar Zero founders conduct a lightweight due-diligence review of each subprocessor at onboarding and annually thereafter. The review covers: (a) currency of SOC 2 Type II / ISO 27001 attestation (verified via the subprocessor's public trust page); (b) review of any public incident disclosures in the prior 12 months; (c) confirmation that the contract / terms of service include breach notification clauses; (d) confirmation that Masar Zero data remains in the agreed geographic region (where applicable).

Due-diligence findings are recorded in a Google Sheet. Any finding that materially increases risk is discussed by founders for a continue-or-replace decision.

7. Periodic Review

The cybersecurity program is reviewed on a planned annual cycle (in July each year, coinciding with the effective date of this policy) and on an ad-hoc basis when significant changes occur. The annual review is conducted by founders and produces a brief written summary (a Google Doc) covering: (a) currency and suitability of all twelve policies; (b) status of the risk register; (c) any incidents from the prior 12 months and lessons learned; (d) subprocessor due-diligence outcomes; (e) any planned changes for the coming year.

Significant changes that trigger ad-hoc review include: (a) onboarding or replacement of a subprocessor; (b) material architecture change; (c) a security incident; (d) a new customer or regulatory requirement. Ad-hoc reviews are logged in the document control block of the affected policy.

8. References

- BAPCO-QR-001 — Master Questionnaire Response (customer-specific cover document).

- MZ-POL-002 through MZ-POL-012 — Companion policies in the suite.
- WorkOS Security — <https://workos.com/security>
- Vercel Security — <https://vercel.com/security>
- Supabase Security — <https://supabase.com/security>
- Google Workspace Security — <https://workspace.google.com/security/>
- GitHub Security — <https://github.com/security>
- 1Password Security — <https://1password.com/security/>

MZ-POL-001 — Cybersecurity & Data Protection Governance Program. End of document.